

PRIVACY MANAGEMENT POLICY

Acme Financial Services

Document Owner: Chief Information Security Officer

Policy ID: PRV-001

Version: 1.0

Effective Date: June 2026

Review Frequency: Annual

Classification: Internal Use

Prepared by: Vearnell Israel

DOCUMENT CONTROL

Document Information	Details
Policy Name	Privacy Management Policy
Policy ID	PRV-001
Version	1.0
Document Owner	Chief Information Security Officer
Classification	Internal Use
Effective Date	June 2026
Review Frequency	Annual
Approval Authority	Executive Leadership Team
Framework Alignment	NIST CSF 2.0, ISO 27001
Next Review Date	June 2027

REVISION HISTORY

Version	Date	Description of Change	Author
1.0	June 2026	Initial Release	Vearnell Israel

1. PURPOSE

The purpose of this Privacy Management Policy is to establish requirements for the collection, use, storage, sharing, protection, retention, and disposal of personal information maintained by Acme Financial Services.

Acme Financial Services is committed to protecting the privacy rights of customers, employees, contractors, business partners, and other individuals whose information the organization processes. Personal information shall be collected and processed in a lawful, transparent, and ethical manner consistent with business objectives, regulatory obligations, contractual requirements, and industry best practices.

This policy establishes a privacy governance framework designed to protect personal information, reduce privacy-related risks, support regulatory compliance, promote transparency, and maintain stakeholder trust.

2. SCOPE

This policy applies to all Acme Financial Services employees, contractors, consultants, temporary workers, vendors, and third-party service providers who collect, access, store, process, transmit, share, or dispose of personal information on behalf of the organization.

This policy applies to all personal information maintained by Acme Financial Services, including customer information, employee records, financial information, identification data, contact information, online activity data, and information maintained by cloud service providers or third-party service providers.

This policy applies to all information systems, databases, applications, cloud environments, business processes, and technologies used to process personal information.

Compliance with this policy is mandatory. Any exception must be documented, reviewed by the Information Security and Compliance teams, and approved by the Chief Information Security Officer or an authorized executive leadership member.

3. PRIVACY MANAGEMENT REQUIREMENTS

3.1 Privacy Governance Program

Acme Financial Services shall maintain a documented privacy management program that establishes accountability, oversight, policies, procedures, and controls designed to protect personal information throughout its lifecycle.

The privacy program shall be reviewed periodically to ensure alignment with applicable laws, regulations, contractual obligations, and organizational objectives.

3.2 Lawful Collection and Processing

Personal information shall only be collected and processed for legitimate business purposes.

Information collected shall be limited to the minimum amount necessary to support business operations, legal obligations, customer services, regulatory requirements, or contractual commitments.

Personal information shall not be collected, used, or disclosed in a manner inconsistent with approved business purposes.

3.3 Consent and Privacy Preferences

Where required by law, regulation, or contractual obligation, Acme Financial Services shall obtain and document appropriate consent before collecting or processing personal information.

Privacy preferences communicated by individuals shall be documented, maintained, and honored in accordance with applicable requirements.

Changes to privacy preferences shall be processed in a timely manner and reflected within applicable systems and records.

3.4 Data Subject Rights

Acme Financial Services shall establish procedures for responding to requests from individuals regarding their personal information.

Subject to applicable legal and regulatory requirements, individuals may request access to their information, correction of inaccurate information, deletion of information, restriction of processing activities, or information regarding how their personal information is being used.

Requests shall be reviewed, documented, and processed in accordance with established procedures.

3.5 Data Accuracy and Quality

Personal information shall be maintained accurately and updated when necessary to support business operations and regulatory requirements.

Reasonable measures shall be implemented to ensure information remains complete, accurate, relevant, and current.

Inaccurate or outdated information shall be corrected promptly upon identification.

3.6 Data Protection and Confidentiality

Personal information shall be protected through appropriate administrative, technical, and physical safeguards commensurate with its sensitivity and classification.

Protection measures may include access controls, encryption, monitoring, data loss prevention technologies, secure transmission methods, logging, vulnerability management, and employee awareness training.

Access to personal information shall be restricted to authorized individuals with a legitimate business need.

3.7 Privacy Impact Assessments

Privacy impact assessments shall be performed when new systems, technologies, products, services, business processes, or third-party engagements involve the collection, processing, or sharing of personal information.

Privacy considerations shall be incorporated into the design, development, implementation, and operation of systems and business processes that process personal information.

Assessments shall evaluate privacy risks, regulatory obligations, data minimization opportunities, security requirements, and mitigation strategies.

Identified privacy risks shall be documented and managed in accordance with established risk management procedures.

3.8 Data Sharing and Third-Party Privacy Requirements

Personal information shall only be shared with third parties when authorized and necessary for legitimate business purposes.

Transfers of personal information across geographic regions or national boundaries shall comply with applicable legal, regulatory, and contractual requirements.

Third parties receiving personal information shall be subject to contractual privacy obligations, security requirements, confidentiality agreements, and risk assessments.

Third-party organizations shall implement safeguards that provide protection consistent with Acme Financial Services privacy and security requirements.

3.9 Data Retention and Disposal

Personal information shall be retained only as long as necessary to satisfy business, legal, regulatory, and contractual requirements.

Retention periods shall be documented and consistently applied.

Information that is no longer required shall be securely deleted, destroyed, anonymized, or otherwise disposed of according to approved data disposal procedures.

3.10 Privacy Monitoring and Recordkeeping

Acme Financial Services shall maintain records supporting privacy compliance activities.

Privacy records may include consent records, privacy preferences, data subject requests, privacy impact assessments, privacy incidents, third-party disclosures, and compliance reviews.

Privacy compliance metrics and key performance indicators shall be periodically reviewed to evaluate the effectiveness of the privacy program.

Privacy-related activities shall be monitored periodically to verify compliance with privacy obligations and organizational requirements.

3.11 Privacy Incident Response

Privacy incidents involving unauthorized access, disclosure, alteration, loss, or destruction of personal information shall be reported promptly.

Privacy incidents shall be investigated in accordance with established incident response procedures.

Where required, affected individuals, regulators, customers, business partners, and other stakeholders shall be notified in accordance with applicable legal and regulatory requirements.

3.12 Privacy Awareness and Training

Employees and contractors with access to personal information shall receive privacy awareness training appropriate to their responsibilities.

Training shall address privacy obligations, information-handling requirements, data protection practices, incident-reporting procedures, and regulatory expectations.

Privacy training shall be provided upon hire and periodically thereafter.

4. POLICY SANCTIONS

Failure to comply with this policy may result in corrective or disciplinary action in accordance with Acme Financial Services' human resources procedures, contractual agreements, and applicable laws.

Disciplinary action may include mandatory privacy awareness training, written warning, suspension of access privileges, contract termination, employment termination, or legal action, depending on the severity of the violation.

Violations involving unauthorized disclosure of personal information, misuse of customer data, failure to comply with privacy obligations, or intentional disregard of privacy requirements may result in additional enforcement actions.

5. REVIEW AND APPROVAL

This policy shall be reviewed annually by the Information Security, Compliance, Legal, Human Resources, and Risk Management teams and approved by executive leadership.

Updates may be made sooner if required due to changes in privacy laws, regulatory requirements, business operations, technology environments, contractual obligations, or cybersecurity risks.

Approved By:

Chief Information Security Officer

Date: _____

Executive Leadership Team

Date: _____